

SonicSiege

None

title: "Campaign Analysis: SonicSiege -- Multi-Vector SonicWall Reconnaissance and Credential Campaign"

author: "Orbie"

created_at: "2026-02-25T06:26:31-05:00"

document_type: campaign_analysis

tags:

- sonicwall
- sonicwall-sonicos
- ssl-vpn
- credential-stuffing
- reconnaissance
- cve-2024-53704
- cve-2021-20028
- cve-2019-7481
- proxy-service-abuse
- bytezero
- gocodeit
- as3257
- as206092
- as211736
- as211590

tlp: amber

visibility: internal

summary: >

Massive coordinated scanning campaign targeting SonicWall SonicOS infrastructure observed 2026-02-22 to 2026-02-25. 80,770 sessions from 6,620 unique IPs across

60 ASNs. Three distinct operational tiers identified: a 4,106-IP proxy spray via

ByteZero/GoCodeIT exit nodes on AS3257/GTT (45% of volume), concentrated scanning clusters in AS211736, AS211590,

AS206092, and AS51396 (36%), and distributed opportunistic scanners (~19%).

Campaign

is overwhelmingly reconnaissance and credential-oriented; malicious exploitation

(CVE-2024-53704, SRA SQLi) is negligible. The /sonicui/7/login/ management path

emerged as a newly significant attack surface indicator.

Campaign Analysis: SonicSiege -- Multi-Vector SonicWall Reconnaissance and Credential Campaign

Author: Orbie

Reviewer: hrbrmstr

Date: 2026-02-25

TLP: AMBER

Workflow: Campaign Identification

Analysis Mode: Comprehensive (100% statistical coverage)

✓ Validation Performed See Validation Report.md (6 Corrections Applied)

✓ Human Analyst Has Reviewed And Augmented The Findings

AI-Assisted Analysis: This report was produced by Orbie, an AI-powered threat intelligence assistant. Analytical narratives, correlation assessments, and speculative conclusions are LLM-generated based on real data queried from GreyNoise, Censys, VirusTotal, and other sources. Outputs undergo automated validation and review by at least one human analyst before distribution. Despite these safeguards, generative and speculative elements may contain errors or inaccuracies.

Executive Summary

Between 2026-02-22 and 2026-02-25, GreyNoise sensors observed a massive, multi-vector scanning and credential campaign targeting SonicWall SonicOS infrastructure. The campaign produced 80,770 sessions^[^1] from 6,620 unique source IPs^[^2] across 60 ASNs^[^3], with a dramatic burst on February 24 that drove a +1,534,950% day-over-day increase in the SonicWall SonicOS API Scanner tag and a +1,930% increase in the SonicWall SSL VPN Login Attempt tag^[^4].

Key Findings:

- Three distinct operational tiers: a 4,106-IP commercial proxy spray via ByteZero/GoCodelT exit nodes (AS3257/GTT transit, 36,451 sessions)^[^5], concentrated scanning clusters (AS211736, AS211590, AS206092, AS51396; 29,237 combined)^[^6], and distributed opportunistic scanners
- Campaign is overwhelmingly reconnaissance and credential-oriented; malicious exploitation tags (CVE-2024-53704, SRA SQLi) accounted for negligible volume^[^7]
- The `/sonicui/7/login/` SonicOS management interface path appeared in 22,710 sessions^[^8] -- a newly prominent attack vector

- Anomalous JA4T TCP fingerprint `65495_2-4-8-1-3_65495_7` (MSS 65495, loopback/tunnel indicator) is dominated by the AS206092/FNS Holdings fleet (~84% of 6,608 sessions)[^9]
- Single dominant JA4H HTTP fingerprint `ge10nr040000_532a1ee47909` ties 43,429 sessions[^10] to a shared automated scanning tool
- The "SonicWall Login Attempt" tag was created just 2026-02-19[^11] -- 3 days before this campaign window opened

Risk Assessment: HIGH -- Active large-scale credential reconnaissance against SonicWall VPN infrastructure, with known critical CVEs (CVE-2024-53704 CVSS 9.8, CISA KEV) available for escalation. The reconnaissance phase typically precedes targeted exploitation.

Campaign Timeline

The campaign exhibits distinct temporal phases:

Phase 1: Baseline Scanning (Feb 22 00:00 -- Feb 23 23:00 UTC)

Steady-state activity averaging 300-400 sessions/hour[^12] from the concentrated scanning clusters (AS211736, AS211590, AS206092). Two brief sub-bursts:

- Feb 22 05:00 UTC: 1,566 sessions/hr (AS211736 activity)
- Feb 23 07:00-08:00 UTC: 1,595-1,958 sessions/hr

Phase 2: Proxy Spray (Feb 24 04:00 -- 12:00 UTC)

The defining event. 36,451 sessions from 4,106 unique IPs[^5] routed through ByteZero commercial proxy exit nodes on GoCodeIT/Xenyth infrastructure (AS3257/GTT transit) in a single 8-hour window. Per-IP volume was extremely low (maximum 13 sessions, average ~9)[^13], consistent with IP rotation by a backconnect proxy service rather than a traditional botnet -- ByteZero's proxy architecture assigns different exit IPs to different sessions, producing a distributed spray pattern. All IPs originated from the 154.208.0.0/16 address space[^14]. The burst peaked at 6,012 sessions/hr at Feb 24 05:00 UTC[^12].

Phase 3: Post-Burst Activity (Feb 24 13:00 -- Feb 25 09:00 UTC)

Activity returned to elevated baseline (300-700 sessions/hr) with periodic micro-bursts from the concentrated clusters.

Phase 4: Secondary Burst (Feb 25 10:00-11:00 UTC)

A new burst emerged at 2,779-4,790 sessions/hr[^12], suggesting ongoing campaign orchestration.

Campaign Architecture

Tier 1: ByteZero Commercial Proxy Spray (45% of campaign)

Metric	Value
Proxy Service	ByteZero (bytezero.io) / ByteProxies (byteproxies.io)[^26]
Infrastructure	GoCodeIT Inc / Xenyth Cloud (AS835), transit via AS3257 (GTT)
Sessions	36,451[^5]
Unique Exit IPs	4,106[^5]
Active Window	Feb 24 04:00-12:00 UTC (8 hours)
Sessions/IP	Max 13, avg ~9[^13]
IP Range	154.208.64.0/21 (within 154.208.0.0/16)[^14]
JA4T	65535_2-1-1-4-1-3_1460_11[^15]
Node Software	flare-riptide (Go binary, pprof-confirmed)[^26]

The 154.208.x.x address space belongs to GoCodeIT Inc (created 2025-03-27), a Canadian hosting/IP transit provider operating as Xenyth Cloud out of Equinix TR2 in Toronto. GTT (AS3257) is their upstream transit provider -- the traffic routes through GTT's backbone but originates from GoCodeIT infrastructure. The exit nodes run ByteZero's proprietary `flare-riptide` proxy software, a Go-based backconnect proxy server identified via exposed pprof debug endpoints[^26].

The extremely low per-IP volume combined with massive IP count is not a botnet spray -- it is a commercial proxy-as-a-service rotating exit IPs across customer sessions. ByteZero's architecture (IP allocator, API key authentication, ClickHouse telemetry for billing, gRPC control plane for user sync) assigns different exit IPs to different sessions, producing a distributed pattern that mimics botnet behavior. **The scanning activity originates from ByteZero's paying customers, not the proxy infrastructure itself.** ByteZero is the anonymization layer enabling the threat actors.

ByteZero's Firebase account was suspended by Google in early December 2025, taking down their customer dashboard. The proxy nodes have been operating headless for ~3 months with

no active abuse mitigation (see Enrichment Findings for details). This directly contributes to the unchecked scanning volume observed in this campaign.

The JA4T fingerprint (window 65535, options MSS-NOP-NOP-SACK-NOP-WScale, MSS 1460, scale 11) indicates a Windows-like TCP stack^[16] with standard Ethernet MTU. This likely reflects the proxy software's TCP parameters rather than the end customers' stacks, since riptide terminates and re-originates connections.

Tier 2: Concentrated Scanning Clusters (36% of campaign)

AS211736 / FOP Dmytro Nedilskyi (Netherlands) -- 7,376 sessions^[16]

IP	Sessions	Behavior
185.156.73.31	4,393 ^[17]	Dual SonicOS API + SSL VPN, /sonicui/7/login/ (2,189 hits)
88.210.63.78	2,940 ^[17]	Dual SonicOS API + SSL VPN, /sonicui/7/login/ (1,456 hits)

These two IPs are the single highest-volume actors in the campaign. Both run identical dual-vector scanning: SonicOS API enumeration ([/api/sonicos/is-sslvpn-enabled](#)) paired with SSL VPN credential attempts, plus heavy [/sonicui/7/login/](#) probing. Registered to the same Ukrainian hosting entity operating from the Netherlands.

AS211590 / Bucklog (France) -- 7,199 sessions^[16]

A cluster of 9+ IPs in the 185.177.72.0/24 range:

IP	Sessions
185.177.72.22	1,797 ^[17]
185.177.72.49	1,224 ^[17]
185.177.72.56	1,051 ^[17]
185.177.72.52	892 ^[17]
185.177.72.38	768 ^[17]
185.177.72.13	753 ^[17]
185.177.72.23	435 ^[17]

IP	Sessions
185.177.72.30	179 ^[17]
185.177.72.51	93 ^[17]

Bucklog is a known bullet-proof hosting provider operating from French infrastructure (Paris, via FBW Networks SAS). The 185.177.72.0/24 block shows coordinated activity patterns consistent with a managed scanning fleet.

AS206092 / F.N.S. Holdings Limited (US) -- 12,705 sessions^[6]

The largest ASN by session count after AS3257, distributed across three IP ranges:

Range	Example IPs	Approx Sessions
136.144.42.0/24	.11-.28, .232-.240	~3,500
172.98.32.0/24	.51-.75	~2,500
45.132.227.0/24	.35-.51	~2,200

Critical finding: The AS206092 fleet is the dominant carrier of the anomalous JA4T fingerprint [65495_2-4-8-1-3_65495_7](#), accounting for ~84% of observed sessions with this fingerprint^[9]. The remaining ~16% appears across 30+ other ASNs (including AWS, DigitalOcean, and Azure), consistent with VPN/tunnel traffic being a general phenomenon -- not a signature exclusive to FNS infrastructure. The fingerprint has MSS 65495 -- the Linux loopback MTU (65535) minus standard TCP/IP headers (40 bytes), indicating traffic originating from or tunneled through a local loopback interface. The JA4 analysis MCP confirmed this as a custom/non-standard encapsulation^[16].

AS51396 / Pfcloud UG (Netherlands) -- 1,957 sessions^[6]

Operating from 204.76.203.0/24. Pfcloud is a hosting provider with a history of association with scanning activity. Top IP 204.76.203.210 (1,110 sessions) had the highest tag diversity (7 distinct tags) in the composite ranking^[18].

Tier 3: Distributed Opportunistic Scanners (~19%)

The remaining ~15,000 sessions come from ~6,400 IPs across 50+ ASNs. Notable contributors include AS42624 (2,606 sessions, single IP 185.196.9.111), AS8075/Microsoft Azure (1,785 sessions), AS213790 (1,321 sessions), AS20473/Vultr (712 sessions), and AS16509/AWS (701 sessions)^[3]. This tier represents the background internet scanning noise that co-occurs with any SonicWall persona.

Attack Vectors

Primary: SonicOS Management Interface Probing

The `/sonicui/7/login/` path (22,710 sessions)^[^8] represents direct access to the SonicOS web management login page. This is the SonicOS 7.x administrative interface -- scanning for exposed management portals. A secondary path `/sonicui/7/login/favicon.ico` (64 sessions) confirms browser-like enumeration behavior.

Secondary: SonicOS API Enumeration

The `/api/sonicos/is-sslvpn-enabled` endpoint (21,674 sessions)^[^8] is a SonicOS REST API call that checks whether SSL VPN functionality is enabled on the device. This is pure reconnaissance -- attackers fingerprint which devices have VPN enabled before attempting credential attacks.

Tertiary: NetExtender VPN Client Abuse

The `/cgi-bin/userLogin` path (5,732 sessions)^[^8] with the user-agent `Dell SonicWALL NetExtender for Linux 7.5.773` (5,733 sessions)^[^19] indicates abuse of the legitimate SonicWall VPN client for automated credential stuffing against the SSL VPN login endpoint.

Ancillary: Opportunistic Exploitation Attempts

Beyond the SonicWall-targeted scanning, multi-purpose scanners in this dataset also probe for:

- Path traversal to `/bin/sh` via CGI (195 sessions)^[^8]
- `.env` file disclosure (140 sessions + traversal variants ~500)^[^8]
- AWS credential theft via `/.aws/credentials` paths (201+ sessions)^[^8]
- `.git/config` exposure (52 sessions)^[^8]
- n8n CVE-2026-21858 (788 sessions)^[^20]
- React CVE-2025-55182 (605 sessions)^[^20]
- AndroXgh0st scanning (630 sessions)^[^20]

These are not SonicWall-specific -- they indicate multi-purpose scanner toolkits that happen to also carry SonicWall tags.

Fingerprint Analysis

JA4H (HTTP Client Fingerprints)

JA4H	Sessions	Decoded	Assessment
ge10nr040000_532a1ee47909	43,429[^10]	HTTP/1.0, GET, no cookies, has referer, 4 headers	Primary scanning tool -- Chrome/119 Linux UA[^19]
po11nn060000_3d8258c9803e	5,732[^10]	HTTP/1.1, POST, no cookies/referer, 6 headers	NetExtender VPN client login submissions
ge11nn14enus_16e29da98f67	5,659[^10]	HTTP/1.1, GET, no cookies/referer, 14 headers, en-US	Chrome/56 macOS UA -- secondary scanner
ge11nn030000_fe444ad14866	3,983[^10]	HTTP/1.1, GET, no cookies/referer, 3 headers	Minimal-header scanner

The dominant fingerprint (ge10nr040000) using HTTP/1.0 with a Chrome/119 UA is immediately suspicious: real Chrome browsers do not use HTTP/1.0. This is a scanning tool masquerading as Chrome. The presence of a Referer header (the **r** flag) without cookies further confirms automated tooling that crudely mimics browser behavior.

JA4T (TCP Client Fingerprints)

JA4T	Sessions	OS Indicators	Assessment
65535_2-1-1-4-1-3_1460_11	36,470[^15]	Windows-like (NOP padding, no timestamp)	ByteZero proxy exit nodes (GoCodeIT/AS3257)
42340_2-4-8-1-3_1460_12	16,282[^15]	Linux (MSS-SACK-Timestamp ordering)	Standard Linux scanning VMs
64240_2-4-8-1-3_1460_10	7,073[^15]	Linux	Standard Linux VPS
65495_2-4-8-1-3_65495_7	6,608[^9]	Linux loopback (MSS=65495)	AS206092/FNS tunnel fleet
64240_2-4-8-1-3_1460_7	3,009[^15]	Linux	Variant scale factor
64240_2-4-8-1-3_1400_7	2,611[^15]	Linux (MTU 1440)	PPPoE/tunnel overhead
65535_2-1-3-1-1-4_1440_8	1,492[^15]	Windows variant (MTU 1440)	Alternate Windows fleet

The JA4T distribution reveals the campaign's infrastructure heterogeneity. The ByteZero proxy nodes present a Windows-era TCP stack (NOP-NOP padding between options, no timestamps) -- likely the riptide binary's own TCP parameters rather than the upstream customers' stacks. The scanning VPS clusters all show standard Linux TCP stacks. The AS206092 loopback signature remains a useful detection indicator for VPN-tunneled traffic, though it is not exclusive to AS206092.

Malicious Exploitation Assessment

Despite the massive reconnaissance volume, actual exploitation attempts against known SonicWall CVEs were negligible:

CVE	Tag	Intention	Sessions	IPs
CVE-2024-53704	SonicWALL SSLVPN Session Hijacking	Malicious	~0-2[^7]	~1
CVE-2021-20028	SonicWALL SRA SQL Injection	Malicious	~2-3[^7]	~2
CVE-2019-7481	SonicWall SRA 4600 SQL Injection	Malicious	~0-2[^7]	~1

All three CVEs are CISA KEV-listed, have public exploits, and are tracked to active threat actors[^21][^22][^23]. However, in this campaign window they appear as background noise, not coordinated exploitation. **This campaign is pre-exploitation -- attackers are mapping the SonicWall attack surface, identifying VPN-enabled devices, and testing credentials. The exploitation phase may follow.**

Geographic Distribution

Country	Sessions	Unique IPs	Notes
Netherlands	~37,000+	~40+	AS211736, AS51396 base
France	~7,200+	~10+	AS211590/Bucklog (Paris)
United States	~15,000+	150+	AS206092/FNS fleet + cloud providers
Canada (GoCodeIT/Xenyth, Toronto)	36,451	4,106	ByteZero proxy exits on 154.208.x.x, transit via AS3257/GTT

The Netherlands and France dominance reflects the hosting infrastructure concentration rather than attacker origin. The 154.208.0.0/16 range belongs to GoCodeIT Inc (Xenyth Cloud), a Canadian hosting provider operating from Equinix TR2 in Toronto, with GTT (AS3257) as upstream transit.

Tag Co-occurrence Analysis

From the full aggregation, tags appearing alongside the 7 SonicWall investigation tags^[^20]:

Co-occurring Tag	Sessions	Significance
Web Crawler	69,070	Generic HTTP scanning marker -- expected
Carries HTTP Referer	44,243	Correlates with primary JA4H fingerprint
TLS/SSL Crawler	8,704	HTTPS scanning subset
CGI Script Scanner	5,954	NetExtender <code>/cgi-bin/userLogin</code> path triggers this
ENV Crawler	4,610	Multi-purpose scanner co-activity
Generic Sensitive File Access	3,461	AWS credentials, .env crawling
SonicWall Login Attempt	282	Newly created tag (Feb 19) -- low volume

The SonicWall Login Attempt tag was created 2026-02-19^[^11] and has only 282 sessions^[^20], suggesting it may not yet have full retroactive coverage or represents a distinct, low-volume authentication pattern separate from the SSL VPN and API scanning.

Enrichment Findings

Censys Infrastructure Profiling (20 IPs)

Key infrastructure linkages discovered via Censys¹:

Bucklog Kubernetes Cluster: The three AS211590 IPs (185.177.72.22, .49, .56) are nodes of a Kubernetes cluster running identical 8-service stacks (SSH, NTP, Cilium eBPF, Envoy proxy,

¹Censys infrastructure enrichment via censys-platform and censys-threat-hunting MCP. 20/20 IPs queried: get_host for each IP, get_host_timeline for key nodes. Full results in censys-enrichment.md.

kubelet, kube-proxy, ingress-nginx). All three share the same expired Cilium CA certificate (SHA256:a3696c...674340, expired 2026-01-04) and HASSH 425d29fe50d8e4f5e37efb6e24bcf660. The network block 185.177.72.0/24 was created 2025-05-27 -- purpose-built scanning infrastructure.

ByteZero/GoCodeIT Proxy Nodes: The Tier 1 exit nodes (154.208.65.225, 154.208.64.17) run identical stacks: throttled SSH (MaxStartups exceeded), authenticated HTTP proxies on ports 30/1111/2222, and the `flare-riptide` Go binary (`/root/flare-riptide/riptide`) exposed via pprof debug endpoint on port 665 (622 goroutines active, main process uptime ~72 days since mid-December 2024)². The 154.208.64.0/21 block is assigned to GoCodeIT Inc / Xenyth Cloud (created 2025-03-27), a Canadian hosting provider operating from Equinix TR2, Toronto.

Post-analysis pprof examination revealed `flare-riptide` is ByteZero's proprietary backconnect proxy node software. Internal package structure confirms: `internal/ipallocator` (exit IP rotation), `internal/acl/keystore` (API key authentication with epoch rotation), `internal/acl/usersync` (gRPC-based subscriber entitlement sync), `internal/acl/reporter.StartByteZeroReporting` (usage telemetry to operator), `pkg/clickhouse` (per-request logging for billing/analytics), `pkg/fb` (Firebase real-time dashboard/billing), and `internal/handlers/http` (forward proxy handler). ByteZero (bytezero.io) markets itself as a commercial proxy service offering 100M+ IPs across 150+ countries for web scraping, SEO, and "data collection." The scanning traffic from these IPs originates from ByteZero's paying customers, not the proxy infrastructure itself.

Headless fleet -- Firebase suspension: ByteZero's Firebase account was suspended by Google around December 4, 2025, taking down their customer-facing dashboard and account management portal. Trustpilot complaints corroborate the outage ("went down entirely in early December 2025 with no customer support for days"). The

²Post-analysis pprof examination of `http://154.208.65.225:665/debug/pprof/goroutine?debug=2`. The goroutine dump revealed Go module path `flare-riptide` built by user `ByteZero` (source at `C:/Users/ByteZero/flare/flare-riptide/`), compiled with Go 1.24.4 on Windows AMD64, cross-compiled for Linux. Internal packages: `internal/ipallocator`, `internal/acl/keystore`, `internal/acl/usersync` (gRPC), `internal/acl/reporter.StartByteZeroReporting`, `pkg/clickhouse` (billing telemetry), `pkg/fb` (Firebase real-time dashboard), `internal/handlers/http` (forward proxy), `internal/listener` (TCP dispatcher), `internal/transport` (outbound TLS), `pkg/dnscache`, `internal/lens` (analytics). Main process uptime: ~72 days (103,530 minutes). ByteZero identity confirmed via bytezero.io (commercial proxy service, 100M+ IPs advertised, domain registered April 2024 via Porkbun) and related brand ByteProxies (byteproxies.io). Trustpilot reviews for ByteProxies confirm port 1111 as proxy listener port, matching Censys observation. Operator handle: "Bvck" per Trustpilot. GitHub org: ByteZeroLabs. Firebase account suspended by Google ~December 4, 2025 (confirmed via ByteZero outage communication screenshot and Trustpilot complaints); customer dashboard down since, proxy nodes operating headless for ~3 months. 2,048 nodes currently responding to pprof.

`pkg/fb.(*BatchUpdateCollector).Start` goroutine in the pprof dump confirms Firebase as the real-time dashboard backend. However, the riptide proxy nodes kept running -- core proxy functionality depends on ClickHouse (logging) and gRPC (user sync), not Firebase. The current riptide process uptime (~72 days, starting mid-December 2025) indicates the nodes were restarted approximately 12 days after the Firebase suspension, possibly to patch out the Firebase dependency or as a routine restart. As of late February 2026, ByteZero has been operating a **headless proxy fleet for approximately three months** -- 2,048 nodes still responding to pprof, customer traffic still flowing through exit nodes, but no active management plane for abuse mitigation or customer access control. Google suspends Firebase accounts for ToS violations (abuse, fraud, content policy violations); the nature of ByteZero's customer traffic makes the cause self-evident. This headless state directly explains the absence of abuse policing during the SonicWall campaign window.

FNS Holdings VPN Exit Infrastructure: All four AS206092 IPs (136.144.42.237, 172.98.32.51, 45.132.227.49, 185.251.19.104) show zero open ports on Censys -- pure outbound-only VPN exit nodes. DNS for 45.132.227.49 reveals Synology QuickConnect and QNAP myqnapcloud mappings, confirming consumer NAS device tunneling. This confirms the JA4T MSS=65495 loopback fingerprint as traffic egressing through VPN tunnels.

FDN3 Paired Scanners: The top two IPs (185.156.73.31, 88.210.63.78) run identical Ubuntu 22.04 stacks with matching HTTP 404 banners on ports 7001-7003 -- a multi-worker scanning framework. The 88.210.63.0/24 block was created 2025-06-13 (recently provisioned).

Shared ARM32 ELF Binary: Two IPs (87.120.191.67, 176.65.132.94) serve an identical ARM32 ELF executable (SHA256:`b42d78...45f64`) on port 9999 -- consistent with a botnet implant or self-updating scanner binary. Both use bulletproof hosting.

Research Scanner: 185.73.23.159 (Ruhr-Universitaet Bochum) is a confirmed academic measurement node with a self-identifying HTTP information page. Recommend excluding from blocking lists.

VirusTotal Reputation Analysis (20 IPs)

Key reputation findings via VirusTotal³:

- 18/20 IPs flagged malicious by at least one vendor (90%)
- **Highest detection:** 204.76.203.210 at 18/93 vendors, reputation -8, with 7 DGA-pattern self-signed SSL certificates and a `/leak/` URL path -- strongest candidate for a credential collection/C2 node

³VirusTotal enrichment via virustotal MCP. 20/20 IPs queried: `get_ip_report` and `get_ip_relationship` (communicating_files, historical_ssl_certificates, resolutions) for each IP. Domain relationship query for lavteam.org. Full results in vt-enrichment.md.

- **Bucklog cluster consensus:** All three 185.177.72.x IPs scored 11-13/93 with negative community reputation -- the tightest malicious cluster and the only IPs with community downvotes
- **lavteam.org association:** 185.196.9.111 previously hosted files.lavteam.org, a documented software crack distribution site with malware-laden referrer files scoring up to 41/77 on VT
- **Worst reputation:** 87.120.191.67 at -9 (12/93 malicious), zero infrastructure artifacts -- freshly provisioned for this campaign
- **No known threat actor attributions:** VT returned no named group associations for any of the 20 IPs
- **Research confirmation:** 185.73.23.159 resolves to softsec.ruhr-uni-bochum.de measurement infrastructure -- likely benign
- 17/20 IPs have zero communicating files -- confirming this is reconnaissance infrastructure, not payload delivery

Full enrichment details: [censys-enrichment.md](#), [vt-enrichment.md](#)

Recommendations

Immediate Actions

1. **Block Scanning Infrastructure:** Block the identified Tier 2 IP ranges at perimeter firewalls:
 - 185.156.73.0/24 (AS211736)
 - 185.177.72.0/24 (AS211590/Bucklog)
 - 136.144.42.0/24, 172.98.32.0/24, 45.132.227.0/24 (AS206092/FNS)
 - 204.76.203.0/24 (AS51396/Pfcloud)
2. **Detection Rules:**
 - Alert on JA4T [65495_2-4-8-1-3_65495_7](#) (AS206092 tunnel signature)
 - Alert on JA4H [ge10nr040000_532a1ee47909](#) (primary scanning tool)
 - Monitor for [Dell SonicWALL NetExtender for Linux 7.5.773](#) user-agent from non-corporate IPs
 - Flag HTTP/1.0 requests with Chrome user-agents (legitimate Chrome does not use HTTP/1.0)
3. **SonicWall-Specific Hardening:**
 - Restrict [/sonicui/7/login/](#) and [/api/sonicos/](#) paths to trusted management IPs
 - Disable SSLVPN if not required; if required, enforce MFA

- Patch all SonicOS devices against CVE-2024-53704 (CVSS 9.8, CISA KEV)
- Decommission any end-of-life SRA appliances vulnerable to CVE-2021-20028 and CVE-2019-7481

Monitoring Recommendations

- Watch for ByteZero/GoCodeIT proxy activity (154.208.x.x via AS3257) to resume -- the 8-hour spray may recur as customers re-engage, and ByteZero may rotate to new IP blocks as current ranges get flagged
- Monitor for follow-on exploitation attempts (CVE-2024-53704 session hijacking) from IPs that previously performed reconnaissance
- Track the SonicWall Login Attempt tag for volume escalation (newly created, likely expanding coverage)

Appendix: Data Sources and Methodology

Primary Data Source: Arkime MCP (GreyNoise Global Observation Grid session data)

Analysis Engine: DuckDB MCP for aggregation analysis

Fingerprint Analysis: JA4 Analysis MCP for TCP and HTTP fingerprint decoding

Tag Intelligence: GreyNoise Intelligence MCP for tag metadata and CVE context

External Enrichment: Censys (infrastructure profiling), VirusTotal (reputation data)

Query: (`http.path:/sonicui/7/login/` OR
`gnTagMetadata.id:cc0e03db-436b-4cde-b2f3-85fcbdf2ab50` OR
`gnTagMetadata.id:8bb71da4-d1b9-4d2d-a388-ea18c3c8dc25` OR
`gnTagMetadata.id:91828e9c-f449-43cb-ab71-d37108b78638` OR
`gnTagMetadata.id:16a84d07-0fa7-4ecd-85d9-80f6c4f66cd2` OR
`gnTagMetadata.id:67e6f283-97a2-45d7-bdad-3ef03a6a9bdd` OR
`gnTagMetadata.id:485799cb-9bfd-4f35-84ca-8ff98fb3bde2` OR
`gnTagMetadata.id:4b7faae8-4850-4a07-9655-7b95ee72f793`) AND
`gnMetadata.persona.name:"Sonicwall Sonicos"`

Time Range: 2026-02-22T00:00:00Z to 2026-02-25T23:59:59Z

Session Count: 80,770 (authoritative from session_stats)

Analysis Mode: Comprehensive -- 100% statistical coverage via session_stats aggregations, strategic sampling via 10,000-session session_search

Data Sources and Citations

End of Report

None

---iocs

ips:

- "185.156.73.31"
- "88.210.63.78"
- "185.196.9.111"
- "185.177.72.22"
- "185.177.72.49"
- "185.177.72.56"
- "185.177.72.52"
- "185.177.72.38"
- "185.177.72.13"
- "185.177.72.23"
- "185.177.72.30"
- "185.177.72.51"
- "172.94.9.28"
- "204.76.203.210"
- "204.76.203.18"
- "204.76.203.69"
- "89.248.168.239"
- "87.120.191.67"
- "185.73.23.159"
- "176.65.132.94"
- "163.245.209.82"
- "78.153.140.147"
- "78.153.140.148"
- "78.153.140.149"
- "185.251.19.104"
- "185.251.19.102"
- "185.251.19.87"
- "185.251.19.99"
- "185.251.19.100"
- "185.251.19.105"
- "68.233.238.110"
- "104.209.148.10"
- "136.144.42.237"
- "136.144.42.240"
- "136.144.42.235"
- "136.144.42.12"
- "136.144.42.21"
- "136.144.42.22"
- "136.144.42.13"
- "172.98.32.51"
- "172.98.32.67"
- "172.98.32.60"


```
- "172.98.32.72"
- "45.132.227.49"
- "45.132.227.37"
- "45.132.227.43"
- "45.132.227.48"
- "45.132.227.45"
- "45.132.227.36"
- "45.132.227.35"
- "45.132.227.51"
cidrs:
- "185.177.72.0/24"
- "136.144.42.0/24"
- "172.98.32.0/24"
- "45.132.227.0/24"
- "204.76.203.0/24"
- "185.251.19.0/24"
- "154.208.64.0/21"
- "154.208.0.0/16"
domains:
- "bytezero.io"
- "byteproxies.io"
- "residential.byteproxies.io"
oast_domains: []
asns:
- 3257
- 206092
- 211736
- 211590
- 51396
- 42624
- 213790
- 202306
cves:
- "CVE-2024-53704"
- "CVE-2021-20028"
- "CVE-2019-7481"
tags:
- "SonicWall SonicOS API Scanner"
- "SonicWall SSL VPN Login Attempt"
- "SonicWall NetExtender Scanner"
- "SonicWALL SSLVPN CVE-2024-53704 Session Hijacking Attempt"
- "SonicWall SRA 4600 SQL Injection Attempt"
- "SonicWALL SRA SQL Injection Attempt"
- "SonicWall Login Attempt"
```

```
fingerprints:
  ja4h:
    - "ge10nr040000_532a1ee47909_000000000000_000000000000"
    - "po11nn060000_3d8258c9803e_000000000000_000000000000"
    - "ge11nn14enus_16e29da98f67_000000000000_000000000000"
    - "ge11nn030000_fe444ad14866_000000000000_000000000000"
  ja4t:
    - "65535_2-1-1-4-1-3_1460_11"
    - "42340_2-4-8-1-3_1460_12"
    - "64240_2-4-8-1-3_1460_10"
    - "65495_2-4-8-1-3_65495_7"
    - "64240_2-4-8-1-3_1460_7"
    - "64240_2-4-8-1-3_1400_7"
    - "65535_2-1-3-1-1-4_1440_8"
  ja4: []
  hassh: []
hashes:
  md5: []
  sha1: []
  sha256: []
urls:
  - "/sonicui/7/login/"
  - "/api/sonicos/is-sslvpn-enabled"
  - "/cgi-bin/userLogin"
  - "/auth.cgi"
user_agents:
  - "Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/119.0.0.0 Safari/537.36"
  - "curl/8.7.1"
  - "Dell SonicWALL NetExtender for Linux 7.5.773"
  - "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_3) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/56.0.2924.87 Safari/537.36"
  - "Mozilla/5.0 (compatible; silver.inc/2.0)"
  - "Go-http-client/1.1"
  - "fasthttp"
ports:
  - 80
  - 443
  - 8080
  - 23
  - 8081
  - 8000
campaigns:
  - "SonicSiege February 2026"
```


ByteZero Proxy Fleet Analysis

ByteZero Proxy Fleet Analysis

flare-riptide Infrastructure Assessment

February 25, 2026

Executive Summary

GreyNoise sensors identified 2,048 IP addresses within the 154.208.64.0/21 netblock (GoCodeIT Inc / Xenyth Cloud, AS835) generating coordinated scanning and exploitation traffic. Investigation revealed these hosts are not independent scanners but exit nodes for **ByteZero** (bytezero.io), a commercial backconnect proxy service. Each node runs a proprietary Go binary called *flare-riptide*, identified through exposed pprof debug endpoints on port 665.

The malicious traffic observed from these IPs originates from ByteZero customers whose requests are proxied through the fleet. ByteZero provides the anonymization and IP rotation layer; its customers are the threat actors generating the scanning, scraping, and exploitation activity.

At the time of collection, the fleet was serving approximately 46,000 simultaneous proxy connections across all nodes, with every node deployed in a single batch on or around December 15, 2024. The entire fleet has been running continuously for 72 days with no restarts or binary updates. ByteZero’s customer-facing portal has been offline since December 4, 2025 due to a Firebase account suspension, meaning the proxy fleet has been operating effectively unmanaged for nearly three months.

Key Findings

Finding	Detail
Fleet Size	2,048 proxy exit nodes on 154.208.64.0/21
Operator	ByteZero (bytezero.io) / ByteZeroLabs
Binary	flare-riptide, built by Windows user "ByteZero" with Go 1.24.4
Hosting	GoCodeIT Inc / Xenyth Cloud (AS835), Toronto — Equinix TR2
Upstream Transit	GTT Communications (AS3257)

Finding	Detail
Deployment Date	December 15, 2024 (single batch, uniform uptime across fleet)
Continuous Uptime	71.9 days (~10.3 weeks) with zero restarts
Active Connections	~46,002 simultaneous proxy sessions at time of scan
Exposed Debug Endpoints	Port 665 (pprof) open on all 2,048 nodes — no authentication
Operational Status	Customer portal offline since Dec 4, 2025 (Firebase suspension); proxy nodes still serving traffic

Infrastructure Overview

The entire fleet occupies a single /21 netblock assigned to GoCodeIT Inc, spanning eight contiguous /24 subnets. The address allocation was created on March 27, 2025 per ARIN records. GoCodeIT operates as Xenyth Cloud (AS835), a legitimate Canadian hosting provider offering VPS, colocation, and BGP transit services from Equinix TR2 in Toronto. There is no indication that GoCodeIT is a bulletproof hosting provider; their published Terms of Service include standard abuse-handling provisions with a 48-hour resolution window.

IP Address Distribution

Subnet	Nodes
154.208.64.0/24	262
154.208.65.0/24	262
154.208.66.0/24	261
154.208.67.0/24	260
154.208.68.0/24	262
154.208.69.0/24	262
154.208.70.0/24	262
154.208.71.0/24	213

Subnet	Nodes
Total	2,048

All eight /24 blocks are fully or nearly fully populated with riptide instances. The final /24 (154.208.71.0/24) has approximately 213 active nodes, suggesting either reserved addresses or a partial deployment.

Binary Architecture

The flare-riptide binary is a purpose-built backconnect proxy node. Source code analysis via pprof stack traces reveals a well-structured Go application with clear separation between proxy handling, access control, telemetry, and infrastructure services. The binary was cross-compiled on a Windows AMD64 system for Linux deployment.

Build Attributes

Attribute	Value
Binary Name	riptide (in /root/flare-riptide/)
Language	Go 1.24.4
Build Platform	Windows AMD64 (cross-compiled for Linux)
Build User	ByteZero
Source Path	C:/Users/ByteZero/flare/flare-riptide/
Parent Namespace	"flare" (suggests a suite of related tools)
Internal Packages	30 unique packages identified

Internal Components

Stack trace analysis reveals the following subsystems, each confirmed present across all parsed nodes:

Package	Function
internal/listener	TCP listener accepting inbound proxy client connections; protocol detection via peek

Package	Function
internal/handlers/http	HTTP proxy request handler using net/http.ReadRequest
internal/transport	Outbound TLS connection management for proxied traffic
internal/ipallocator	Exit IP pool management with rotation and cleanup routines
internal/acl/keystore	API key/token authentication with epoch-based rotation
internal/acl/usersync	Subscriber entitlement sync via gRPC from central control plane
internal/acl/reporter	StartByteZeroReporting — usage telemetry to operator
internal/lens	Batch processing workers for traffic metadata (10 workers per node)
internal/proxytunnel/local	Local proxy tunnel handling (CONNECT method support)
pkg/clickhouse	ClickHouse integration for per-request logging and billing analytics
pkg/fb	Firebase BatchUpdateCollector for real-time dashboard stats
pkg/dnscache	Custom DNS resolver cache with 11-minute refresh cycle
pkg/meili	MeiliSearch integration (plan and subscription data)

Component Coverage

Every component was present on all successfully parsed nodes, confirming a homogeneous fleet running identical binary builds:

Component	Nodes Present	Coverage
bytezero reporter	2,047	99.9%
dns cache	2,047	99.9%

Component	Nodes Present	Coverage
firebase collector	2,047	99.9%
ip allocator	2,047	99.9%
key store	2,047	99.9%
pprof server	2,048	100.0%
user sync	2,047	99.9%

Operational Scale

The following metrics represent a point-in-time snapshot captured during the scan window. These values reflect concurrent activity, not cumulative throughput.

Fleet-Wide Connection Summary

Metric	Value
Total Proxy Exit Nodes	2,048
Active Proxy Connections	~46,002
Active HTTP Handlers	~11,113
Total Goroutines	~216,121
ClickHouse Pool Connections	~85,973
gRPC Control Plane Connections	~49,636
Redis Connections	~8,188

Per-Node Connection Distribution

Active proxy connections are distributed evenly across the fleet, consistent with a load-balanced backconnect architecture:

Statistic	Connections
Minimum	0

Statistic	Connections
25th Percentile	19
Median	22
Mean	22.5
75th Percentile	25
95th Percentile	33
Maximum	142
Std Dev	5.94

Connection Bucket Distribution

Connections	Nodes	Pct
0	1	0.1%
1-10	0	0.0%
11-20	875	42.7%
21-30	946	46.2%
31-40	224	11.0%
41-50	0	0.0%
51+	1	0.1%

The tight distribution (IQR: 19–25 connections per node) indicates effective load balancing distributing customer sessions evenly. The single outlier at 142 concurrent connections on 154.208.67.236 may represent a high-volume customer with sticky session affinity.

Deployment Analysis

All 2,048 nodes were deployed in a single batch. The uptime distribution across the fleet is remarkably uniform:

Metric	Value
Minimum Uptime	71.92 days
Maximum Uptime	71.93 days
Mean Uptime	71.92 days
Std Dev	0.0023 days
Deployment Date	2025-12-15
Deployment Method	Single batch (std dev < 4 minutes across entire fleet)

The standard deviation of 0.0023 days (approximately 3.3 minutes) across all nodes confirms a fully automated, orchestrated deployment. Every node was provisioned, configured, and started within a window of roughly 10 minutes. No node has been restarted, updated, or redeployed since.

The deployment date of December 15, 2024 is notable because ByteZero's Firebase account was suspended and their customer portal went offline on December 4, 2025 — nearly 12 months after this fleet was stood up. The fleet has continued operating for approximately three months past the portal outage, indicating full autonomy of the proxy node infrastructure from the customer management layer.

Operational Security Exposure

Every node in the fleet exposes Go's built-in pprof debug interface on port 665 with no authentication. This endpoint provides real-time introspection into the running process, including complete goroutine stack traces with source file paths, function names, wait durations, and internal package structure.

This exposure allowed full architectural reconstruction of the riptide binary without access to the source code or the binary itself. The information disclosed includes the developer's Windows username and file paths, all internal package names and their relationships, third-party dependency versions, real-time connection counts and durations, the function of every subsystem, and the explicit function name `StartByteZeroReporting` that attributes the operation.

Busiest Nodes

IP Address	Active Proxy Connections
154.208.67.236	142
154.208.65.10	38
154.208.65.9	38
154.208.65.14	38
154.208.65.11	37
154.208.65.7	37
154.208.65.12	37
154.208.65.39	37
154.208.65.13	37
154.208.65.8	37

Backend Infrastructure

The goroutine dumps reveal the control plane dependencies that each riptide node connects to:

Service	Role
ClickHouse	Per-request logging for billing and analytics. 42 persistent connections per node (~86,000 fleet-wide). Tables: processTrafficPulseBuffer, processUserLogsBuffer.
gRPC	Control plane for user/subscription synchronization. ~24 connections per node for ACL user sync and dedicated plan management.
Redis	Session state, rate limiting, and real-time coordination. 4 connections per node.
Firebase	Real-time dashboard metrics via BatchUpdateCollector. Account suspended Dec 4, 2025; goroutines still attempting reconnection.

Service	Role
MeiliSearch	Plan and subscription data indexing (pkg/meili/plans, pkg/meili/dedicated).
DNS Cache	Custom resolver cache with 11-minute TTL refresh cycle; avoids upstream DNS dependency.

The ClickHouse connection count is notable. At 42 connections per node and 2,048 nodes, the fleet maintains approximately 86,000 concurrent database connections. This suggests either a centralized ClickHouse cluster handling substantial write volume, poor connection pool management, or both.

Attribution

Evidence	Detail
Function Name	internal/acl/reporter.StartByteZeroReporting explicitly names the operator in source code
Build User	Windows build user "ByteZero" matches the brand name
Domain	bytezero.io registered April 26, 2024 via Porkbun; privacy-protected WHOIS
GitHub	ByteZeroLabs organization with proxy-guard, geo.bytezero.io, country-to-asn repos
LinkedIn	Registered as "ByteZero Data Technologies"
Port Correlation	Trustpilot customer complaints reference port 1111; matches observed proxy listener ports on fleet
Service Description	Marketed as 100M+ IP residential/datacenter proxy service for scraping, SEO, and automation
Related Brand	ByteProxies (byteproxies.io) — earlier or parallel brand; operator referenced as "Bvck"

Evidence	Detail
Outage Correlation	Dec 4, 2025 Firebase suspension matches Trustpilot complaints about service downtime on same date

Conclusions

The 154.208.64.0/21 netblock hosts a 2,048-node proxy fleet operated by ByteZero, a commercial backconnect proxy service. The malicious scanning and exploitation traffic observed by GreyNoise from these IPs is generated by ByteZero's customers and routed through the fleet as exit nodes. The riptide binary itself is not a scanner; it is the proxy infrastructure layer providing anonymization and IP rotation.

The fleet represents a meaningful-scale proxy operation: approximately 46,000 concurrent proxy sessions distributed across 2,048 nodes, all on a single hosting provider, all deployed simultaneously, and all running identical builds with debug endpoints exposed. The uniform deployment and zero-restart uptime suggest a single operator managing the infrastructure through automation with minimal ongoing maintenance.

The three-month gap between the customer portal outage and continued fleet operation raises questions about abuse handling. With no functional customer management interface and customer support reportedly unresponsive, there is no apparent mechanism for ByteZero to respond to abuse reports, terminate misbehaving customers, or enforce acceptable use policies. The proxy fleet is effectively running on autopilot, serving whatever traffic its authenticated customers route through it.

GoCodeIT / Xenyth Cloud appears to be a legitimate hosting provider that may not be aware a commercial proxy service is operating exit nodes on their infrastructure. Standard abuse reporting to GoCodeIT's published contacts (referencing their 48-hour resolution policy) would be the appropriate next step to address the scanning traffic originating from this netblock.

Methodology

This analysis is based on pprof goroutine debug dumps (debug=2) collected from 2,001 of the 2,048 identified nodes. The pprof endpoint at /debug/pprof/goroutine?debug=2 on port 665 was accessible without authentication on all responding hosts. Three nodes returned HTTP authentication errors and were excluded from statistical analysis. Fleet-wide extrapolations use a scaling factor of 1.025 to project from 1,998 parsed nodes to the full 2,048-node fleet. All IP distribution, connection, and component statistics are derived directly from the goroutine stack traces. No binary samples were obtained; all architectural conclusions are based on function names, package paths, and wait-state annotations present in the pprof output.

